Securing SQL Server 2016 Databases

Gianluca Hotz
@glhotz
www.ugiss.org

Sponsors

CONSORZIO
UNIVERSITARIO
DI PORDENONE

Organizers

CONSORZIO
UNIVERSITARIO
DI PORDENONE

Gianluca Hotz | @glhotz

- Fondatore e Mentor SolidQ
  - 20 anni con SQL Server (dalla 4.21 nel 1996)
  - Modellazione basi di dati, dimensionamento e amministrazione, sviluppo, ottimizzazione
- Interessi
  - Modello relazionale, architettura DBMS, alta disponibilità e Disaster Recovery
- Microsoft MVP SQL Server dal 1998
- Fondatore e presidente UGISS
  - User Group Italiano SQL Server (PASS Chapter)

Agenda

Introduction

Always Encrypted

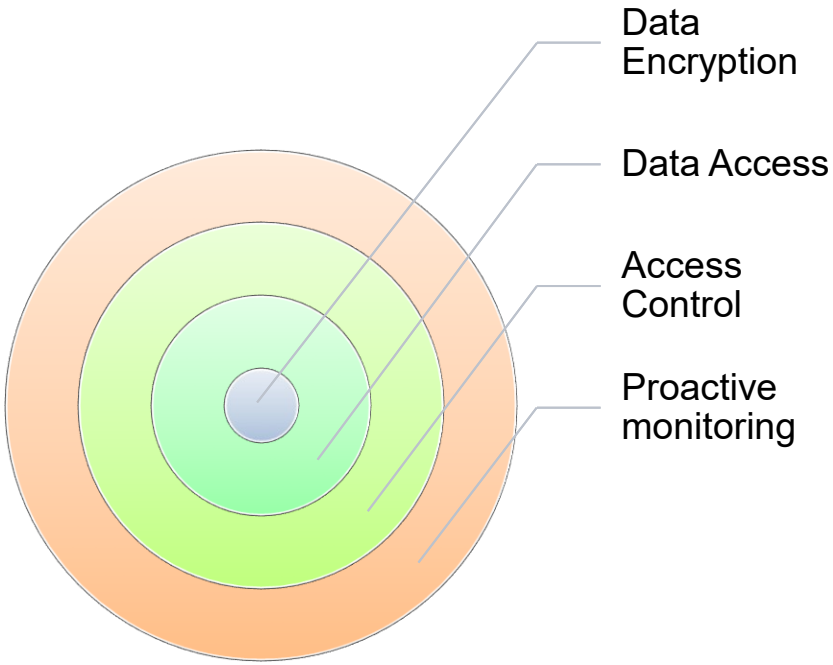
Row-level Security

Data Masking

Securing SQL Server 2016 Databases

INTRODUCTION

Security Layering



Data Encryption

- Transport Layer Security (in transit)
- Transparent Data Encryption (at rest)
- Cell-Level Encryption (at rest)
- Always Encrypted (at rest and in transit)

Data Access

- Dynamic Data Masking
- Row-Level Security

Access Control

- Encrypted Authentication
- SQL Firewall*

Proactive monitoring

- Auditing
- Threat Detection*

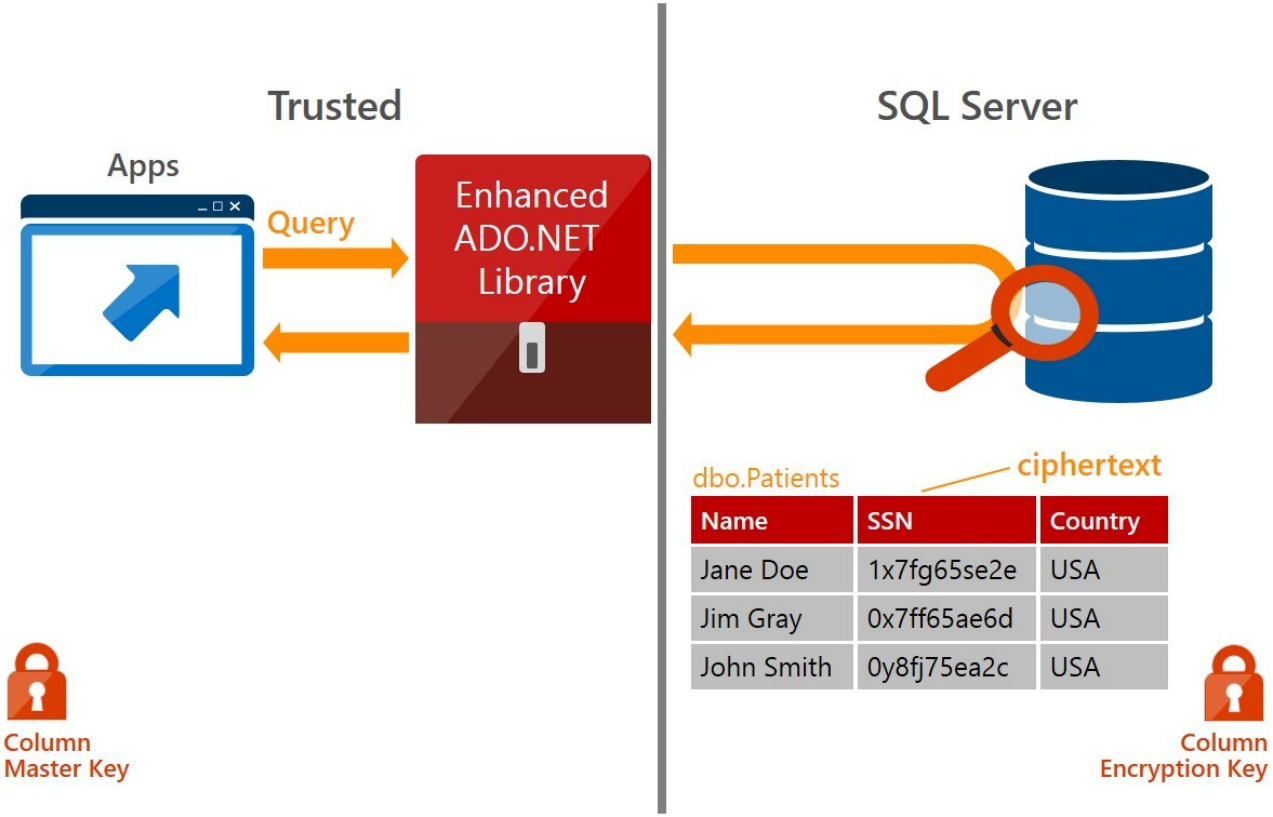
Securing SQL Server 2016 Databases

ALWAYS ENCRYPTED

Encryption Before 2016

- Transparent Data Encryption (TDE)
  - Data, log and backup files
  - Data decrypted when loaded in memory*
  - Fully transparent to applications
- Cell-Level Encryption (CLE)
  - Column level granularity
  - Partial protection in memory
  - Not transparent to applications
- Both Server-Side Encryption
  - Protect data at rest (e.g. theft of drives or backup sets)
  - High privilege users can gain access to data

Always Encrypted Overview



Always Encrypted Keys

- Column Encryption Key (CEK)
  - Used to encrypt data
  - Stored in encrypted form as metadata on server
  - Bound to specific column(s)

- Column Master Key (CMK)
  - Used to encrypt CEKs
  - Stored in a external key store
    - Windows Certificate Store, Azure Key Vault, HSM, Custom
  - Must be available to applications

Data Encryption

- Deterministic
  - Allows equality/grouping/join operations
  - Allows indexing
  - Weaker e.g. small value domains like Sex or Flags
  - Requires _BIN2 collation!

- Randomized
  - No operations allowed
  - No indexing
  - Strongest

Always Encrypted Configuration

- SQL Server Management Studio
  - End-to-End Wizard
  - Specific dialogs
  - Rotation scenarios supported
- Only part of the configuration in T-SQL
  - Unencrypted CMK available only externally
- PowerShell

Always Encrypted Client Configuration

- Connection String
  - Column Encryption Setting=Enabled
- Single Command
  - SqlCommand.ColumnEncryptionSetting*
    - Disabled, Enabled, ResultSetOnly, UseConnectionSetting

Always Encrypted Parameters

- Parametrized statements requires round-trip
  - Call to sys.sp_describe_parameter_encryption
  - Returns columns keys metadata and encrypted key
  - .NET Framework 4.6.2 avoid round-tripping by implementing a cache on the application-tier

- In general
  - No ad-hoc queries with literal predicates
  - No operations involving cyphertexts and plaintexts
  - Nothing that requires unencrypted data on server

Always Encrypted

DEMO

Securing SQL Server 2016 Databases

ROW LEVEL SECURITY

Row Level Security Overview

- Restricts access to a subset of rows
- Based on Security Predicates
  - Defined as inline Table-Valued Functions
  - Filter predicates restrict rows to read operations
    - SELECT, UPDATE and DELETE
  - Block predicates block write operation
    - AFTER INSERT, AFTER/BEFORE UPDATE, BEFORE DELETE
- Security Policy
  - Applies Security Predicates to tables

Row-Level Security

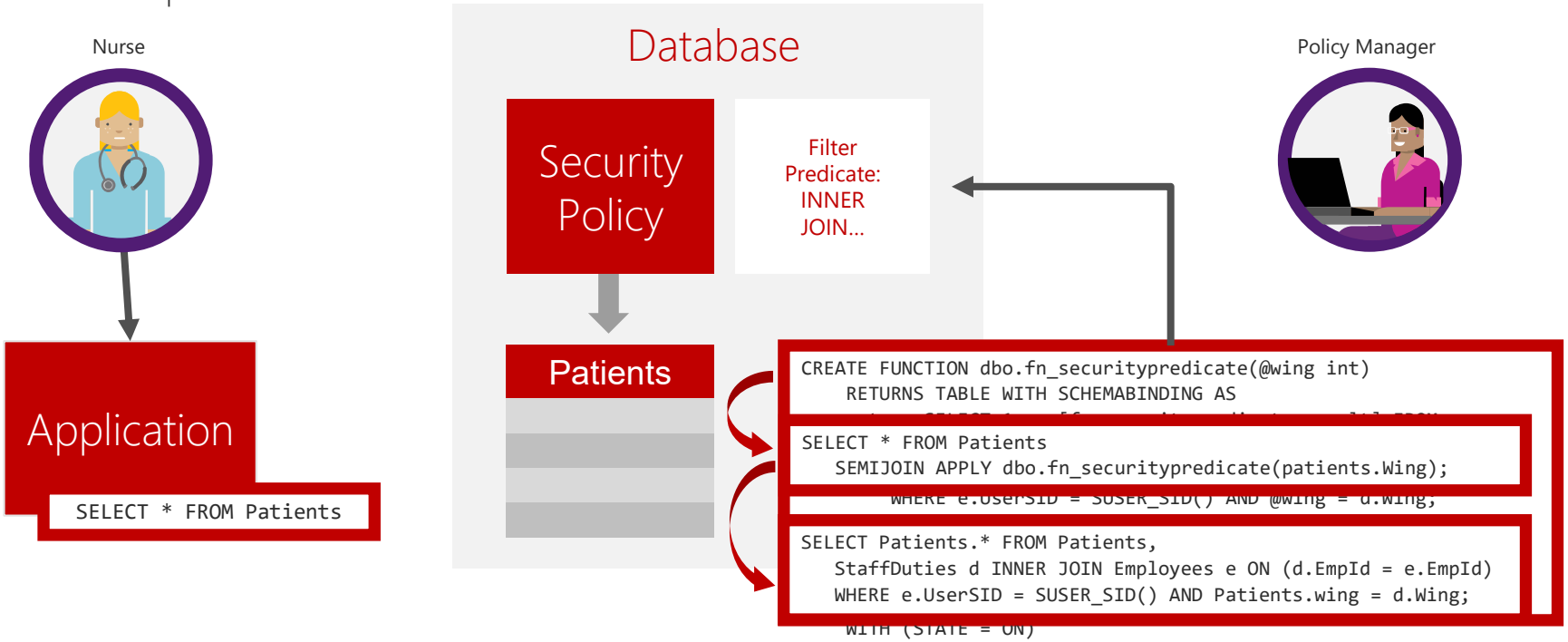
Due

Policy Manager creates a security policy that applies a predicate

Nurse logs in and runs a SELECT against the Patients table

The security policy rewrites the query to include the predicate

Nurse logs in and runs a SELECT against the Patients table. The security policy rewrites the query to include the predicate based on the user ID and a security policy that constrains the predicate to the Patients table.



Row-Level Security & Multi Tenancy

- Restrict tenant access when shards shares same tables
- Assuming there's a column identifying the tenant

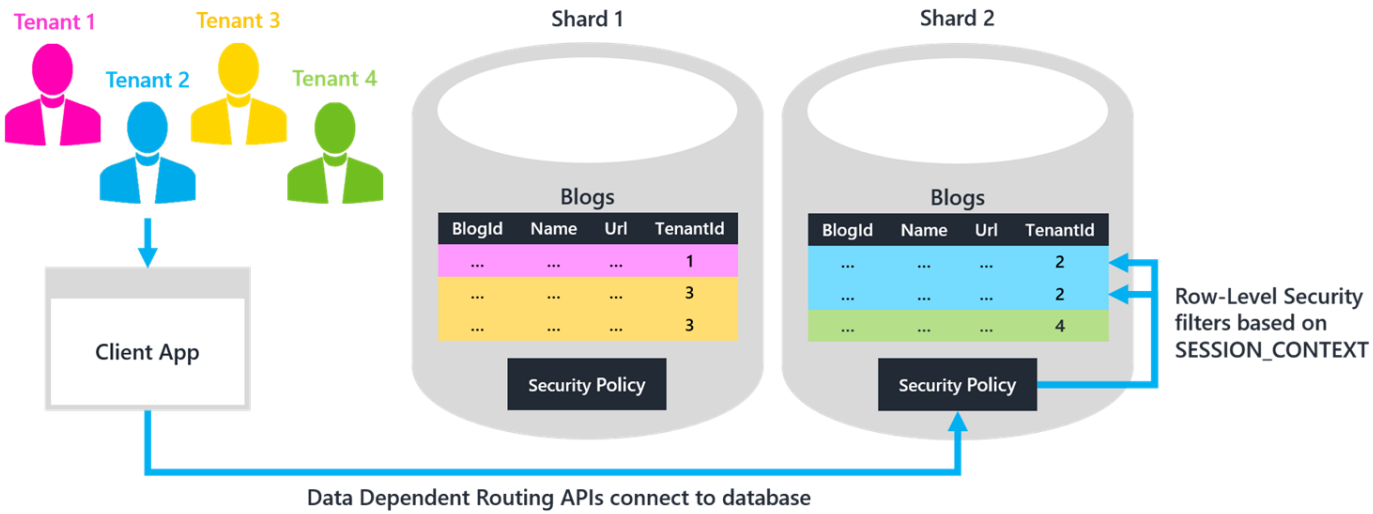


Image source: https://docs.microsoft.com/en-us/azure/sql-database/sql-database-elastic-tools-multi-tenant-row-level-security

Row Level Security

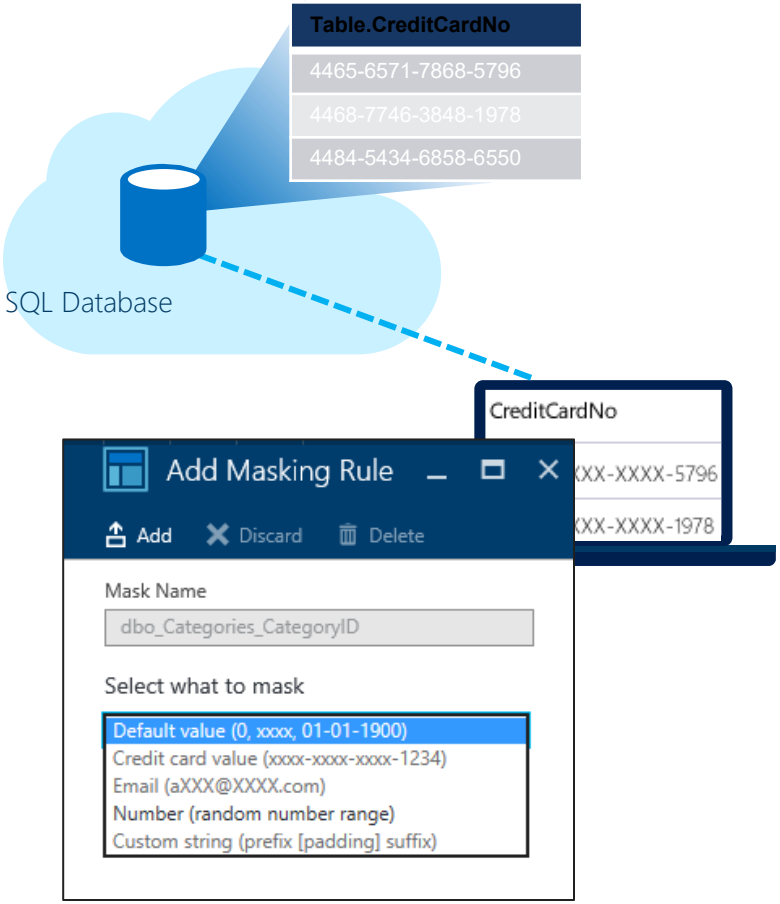
DEMO

Securing SQL Server 2016 Databases

DYNAMIC DATA MASKING

Dynamic Data Masking

- Masking
  - Real-time
  - Different mask type
  - Partial masks
- Rule/permission based
  - Column level
  - Permissions to unmask
- Azure configuration in portal



Dynamic Data Masking

DEMO

Dynamic Data Masking Functions

- Default
  - Type dependent ‘X’, 0, 01.01.1900 00:00:00.0000000
- Email
  - aXXX@XXXX.com
- Random
  - Integer range
- Custom String
  - Prefix length, [padding char], suffix length

Dynamic Data Masking Permissions

- CRATE and ALTER table
- ALTER ANY MASK (w/ ALTER on table)
- UNMASK
- Can still update data!

Dynamic Data Masking Gotchas

- Beware when moving data
  - Export/Import
  - SELECT…INTO
  - INSERT…SELECT…FROM
- Brute-force techniques
  - Value inference with range predicates
  - Domain table

Securing SQL Server 2016 Databases

AZURE SQL DATABASE ONLY

«SQL Database Auditing»

- Similar to SQL Server Audit
  - No T-SQL support (portal, PowerShell, REST API)
- Events destinations
  - Table in "Azure Storage Table"
  - File in "Azure Storage Blob"
- Analysis
  - Extended Events file (SSMS, PowerShell, C# library)
  - Pre-configure Excel file with Power Query

SQL Database Threat Detection (preview)

- Simple per-database option to activate
  - Requires activation of "SQL Database Auditing"
- Detects potential threats/vulnerabilities
  - "SQL Injection" kind of attacks
  - Unusual accesses (e.g. from unusual places)
- Alarms
  - Real-time
  - Recommendations on what to investigate/how to mitigate/remediate

Azure Security Center

- Service to manage security resources in Azure
- Recommendations also for Azure SQL Database
  - Encryption (e.g. TDE)
  - Audit & Monitor (e.g. Server/Database Auditing)
  - Dynamic Data Masking (e.g. sensible data)

Resources

- Documentation
  - http://aka.ms/AlwaysEncrypted
- SQL Server Security Blog
  - https://blogs.msdn.microsoft.com/sqlsecurity
- MVA Course
  - https://mva.microsoft.com/en-US/training-courses/16076
- GitHub Samples
  - https://github.com/Microsoft/azure-sql-security-sample
  - https://github.com/Microsoft/sql-server-samples

#sqlsat589

THANKS! Q&A